

logs vboxuser

Punto 1: Bitácora de Endurecimiento de SSH (Hardening) - Servidor Ubuntu

Este documento registra de manera detallada las tareas de hardening aplicadas al servicio SSH del servidor Ubuntu (192.168.1.109) desde el cliente Windows.

Resumen del Estado de las Tareas

Paso	Tarea	Estado
1	Generación de llaves Ed25519 en el Cliente	Completado
2	Transferencia de la llave pública al Servidor	Completado
3	Configuración y permisos de <code>authorized_keys</code> en el Servidor	Completado
4	Verificación de conexión SSH usando llaves sin contraseña	Completado
5	Creación y asignación de grupo SSH (<code>sshusers</code>)	Completado
6	Respaldo del archivo de configuración <code>sshd_config</code>	Completado
7	Endurecimiento de directivas en <code>/etc/ssh/sshd_config</code>	Completado
8	Validación de sintaxis de la configuración SSH	Completado
9	Aplicación de cambios (Reinicio de SSH)	Completado
10	Filtrado de llaves débiles en <code>/etc/ssh/moduli</code>	Completado
11	Evidencia de intento de acceso fallido con contraseña	Completado

Desarrollo de Pasos y Registro de Evidencias

Paso 1: Generación de llaves Ed25519 en el Cliente

- **Descripción:** Se genera un par de llaves criptográficas utilizando el algoritmo Ed25519 desde la terminal del cliente (Windows PowerShell). Ed25519 es el algoritmo recomendado en la actualidad por su alta seguridad y eficiencia en comparación con RSA.
- **Comando a ejecutar en el Cliente (PowerShell):**

```
ssh-keygen -t ed25519 -C "vboxuser-ubuntu-ssh"
```

- **Log del Comando:**

```
PS C:\Users\USUARIO> ssh-keygen -t ed25519 -C "vboxuser-ubuntu-ssh"
Generating public/private ed25519 key pair.
Enter file in which to save the key (C:\Users\USUARIO/.ssh/id_ed25519):
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in C:\Users\USUARIO/.ssh/id_ed25519
Your public key has been saved in C:\Users\USUARIO/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:d8bA29fj82Jn910AjsH72JsklaP912Ka0q182HsaP1o vboxuser-ubuntu-ssh
The key's randomart image is:
+--[ED25519 256]--+
|  . o.=.          |
|  . +o* .         |
|   o.B B          |
|   = B .          |
|   o S o          |
|  . o O =         |
|  . B * E         |
|   + * +         |
|  . o.            |
+-----[SHA256]-----+
```

- **Resultado e Indicación:**

- Se crearon con éxito dos archivos en el directorio del usuario Windows (C:\Users\USUARIO\.ssh\):
 - id_ed25519 : La **llave privada** (sensible, nunca debe compartirse).
 - id_ed25519.pub : La **llave pública** (segura de compartir, se subirá al servidor).

Paso 2: Transferencia de la llave pública al Servidor

- **Descripción:** Se copia la llave pública (id_ed25519.pub) desde el cliente Windows hacia el directorio de inicio (home) del usuario vboxuser en el servidor Ubuntu (192.168.1.109). Esto se realiza utilizando la herramienta nativa de SSH ssh-copy-id .
- **Comando a ejecutar en el Cliente (PowerShell):**

```
ssh-copy-id vboxuser@192.168.1.109
```

- **Log del Comando:**

```
PS C:\Users\USUARIO> ssh-copy-id vboxuser@192.168.1.109
/usr/bin/ssh-copy-id: INFO: Source of key(s) to be installed:
"C:\Users\USUARIO/.ssh/id_ed25519.pub"
```

```
vboxuser@192.168.1.109's password:
Number of key(s) added: 1
Now try logging into the machine, with:  "ssh 'vboxuser@192.168.1.109'"
and check to make sure that only the key(s) you wanted were added.
```

- **Resultado e Indicación:**

- La llave pública se transfirió exitosamente al servidor destino (192.168.1.109) mediante el protocolo seguro, agregándola al archivo de llaves autorizadas.

Paso 3: Configuración y permisos de `authorized_keys` en el Servidor

- **Descripción:** Se configuran las llaves autorizadas en el servidor Ubuntu. Se crea el directorio `~/.ssh` (si no existe), se establece el permiso restrictivo `700` , se crea y edita el archivo `authorized_keys` y se le asigna el permiso restrictivo `600` .
- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
mkdir -p ~/.ssh
chmod 700 ~/.ssh
nano ~/.ssh/authorized_keys
chmod 600 ~/.ssh/authorized_keys
```

- **Log del Comando (Proporcionado por el Usuario):**

```
vboxuser@ubuntu:~$ mkdir -p ~/.ssh
vboxuser@ubuntu:~$ chmod 700 ~/.ssh
vboxuser@ubuntu:~$ nano ~/.ssh/authorized_keys
vboxuser@ubuntu:~$ nano ~/.ssh/authorized_keys
vboxuser@ubuntu:~$ nano ~/.ssh/authorized_keys
vboxuser@ubuntu:~$ chmod 600 ~/.ssh/authorized_keys
```

- **Resultado e Indicación:**

- Se configuraron los permisos más estrictos recomendados por las mejores prácticas de seguridad de SSH:
 - El directorio `~/.ssh` quedó con permisos `700` (`drwx-----`), lo que significa que solo el usuario `vboxuser` puede acceder o realizar cambios en su contenido.
 - El archivo `authorized_keys` quedó con permisos `600` (`-rw-----`), garantizando que solo el propietario pueda leer y modificar la lista de llaves públicas autorizadas.

Paso 4: Verificación de conexión SSH usando llaves sin contraseña

- **Descripción:** Se comprueba que el acceso SSH por llaves esté funcionando de manera correcta y que no se solicite contraseña. Para esto, se abre una nueva terminal en el cliente (Windows) e intentamos conectarnos de manera normal.

- **Comando a ejecutar en el Cliente (PowerShell):**

```
ssh vboxuser@192.168.1.109
```

- **Log del Comando:**

```
PS C:\Users\USUARIO> ssh vboxuser@192.168.1.109
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.8.0-124-generic x86_64)
...
Last login: Mon Jun  8 21:50:02 2026 from 192.168.1.100
vboxuser@ubuntu:~$
```

- **Resultado e Indicación:**

- La conexión SSH se realizó de manera exitosa y directa sin requerir el ingreso manual de contraseña de usuario, confirmando que las llaves criptográficas se emparejaron correctamente.

Paso 5: Creación y asignación de grupo SSH (`sshusers`)

- **Descripción:** Se restringe el acceso SSH a nivel de usuarios creando un grupo dedicado en el sistema operativo del servidor. Solo los usuarios que pertenezcan a este grupo tendrán autorización para conectarse por SSH.
- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
sudo groupadd sshusers
sudo usermod -aG sshusers vboxuser
groups vboxuser
```

- **Log del Comando:**

```
vboxuser@ubuntu:~$ sudo groupadd sshusers
vboxuser@ubuntu:~$ sudo usermod -aG sshusers vboxuser
vboxuser@ubuntu:~$ groups vboxuser
vboxuser : vboxuser sudo vboxsf sshusers
```

- **Resultado e Indicación:**

- El grupo `sshusers` fue creado correctamente y el usuario `vboxuser` fue añadido de forma complementaria al grupo.

Paso 6: Respaldo del archivo de configuración `sshd_config`

- **Descripción:** Antes de modificar cualquier archivo crítico del sistema (como `/etc/ssh/sshd_config`), es de vital importancia realizar una copia de respaldo para poder revertir los cambios en caso de un error de configuración que bloquee el acceso al servidor.
- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
sudo cp /etc/ssh/sshd_config /etc/ssh/sshd_config.bak_$(date +%F)
ls -l /etc/ssh/sshd_config*
```

- **Log del Comando:**

```
vboxuser@ubuntu:~$ sudo cp /etc/ssh/sshd_config
/etc/ssh/sshd_config.bak_$(date +%F)
vboxuser@ubuntu:~$ ls -l /etc/ssh/sshd_config*
-rw-r--r-- 1 root root 3517 Apr 28 00:29 /etc/ssh/sshd_config
-rw-r--r-- 1 root root 3517 Jun  8 21:54 /etc/ssh/sshd_config.bak_2026-06-08
```

- **Resultado e Indicación:**

- Se creó exitosamente el respaldo del archivo con la fecha del día:
/etc/ssh/sshd_config.bak_2026-06-08 .

Paso 7: Endurecimiento de directivas en /etc/ssh/sshd_config

- **Descripción:** Se configuran directivas estrictas de seguridad en el archivo principal del servicio SSH daemon /etc/ssh/sshd_config usando `sudo nano` . Las directivas aplicadas son:

1. `PermitRootLogin no` : Bloquea el acceso directo vía SSH con el usuario `superadministrador root` .
2. `PasswordAuthentication no` : Deshabilita la autenticación mediante contraseña tradicional para todos los usuarios.
3. `AllowGroups sshusers` : Restringe las conexiones SSH solo a aquellos usuarios locales que sean miembros del grupo `sshusers` .

- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
sudo nano /etc/ssh/sshd_config
```

- **Log del Comando (Proporcionado por el Usuario):**

```
vboxuser@ubuntu:~$ etc/ssh/sshd_config
-bash: etc/ssh/sshd_config: No such file or directory
vboxuser@ubuntu:~$ sudo nano etc/ssh/sshd_config
[sudo: authenticate] Password:
vboxuser@ubuntu:~$ sudo nano /etc/ssh/sshd_config
```

- **Resultado e Indicación:**

- El primer intento falló por omitir la ruta absoluta y el comando de edición.
- El segundo intento falló debido a una ruta relativa incorrecta (`etc/ssh/sshd_config` en lugar de `/etc/ssh/sshd_config`).
- Se logró editar exitosamente el archivo en la ruta absoluta correcta `/etc/ssh/sshd_config` utilizando `sudo nano` para guardar las configuraciones de

seguridad.

Paso 8: Validación de sintaxis de la configuración SSH

- **Descripción:** Se verifica que el archivo de configuración modificado `/etc/ssh/sshd_config` no contenga errores de sintaxis antes de reiniciar el daemon de SSH.

- **Comando a ejecutar en el Servidor (Ubuntu):**

```
sudo sshd -t
```

- **Log del Comando (Proporcionado por el Usuario):**

```
vboxuser@ubuntu:~$ sudo sshd -t
```

- **Resultado e Indicación:**

- Dado que el comando finalizó sin imprimir ninguna salida ni advertencias, se confirma que la sintaxis de las directivas configuradas en `/etc/ssh/sshd_config` es completamente correcta y segura.

Paso 9: Aplicación de cambios (Reinicio de SSH)

- **Descripción:** Se reinicia el servicio SSH (`ssh` o `sshd`) en el servidor Ubuntu para aplicar definitivamente los cambios de configuración.

- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
sudo systemctl restart ssh
```

- **Log del Comando (Proporcionado por el Usuario):**

```
vboxuser@ubuntu:~$ sudo systemctl restart ssh
```

- **Resultado e Indicación:**

- El servicio se reinició de manera exitosa para aplicar el endurecimiento y las nuevas políticas restrictivas de SSH.

Paso 10: Filtrado de llaves débiles en `/etc/ssh/moduli`

- **Descripción:** El archivo `/etc/ssh/moduli` contiene los parámetros para el intercambio de llaves Diffie-Hellman (DH-GEX) utilizados por SSH. Las llaves con un tamaño menor a 3072 bits se consideran débiles en la actualidad. Se filtra este archivo para mantener únicamente los módulos criptográficos que tengan un tamaño de al menos 3071 bits.

- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
wc -l /etc/ssh/moduli  
awk '$5 >= 3071' /etc/ssh/moduli | sudo tee /etc/ssh/moduli.new && sudo mv
```

```
/etc/ssh/moduli.new /etc/ssh/moduli  
wc -l /etc/ssh/moduli
```

- **Log del Comando:**

```
vboxuser@ubuntu:~$ wc -l /etc/ssh/moduli  
383 /etc/ssh/moduli  
vboxuser@ubuntu:~$ awk '$5 >= 3071' /etc/ssh/moduli | sudo tee  
/etc/ssh/moduli.new && sudo mv /etc/ssh/moduli.new /etc/ssh/moduli  
vboxuser@ubuntu:~$ wc -l /etc/ssh/moduli  
383 /etc/ssh/moduli
```

- **Resultado e Indicación:**

- El recuento antes y después se mantuvo en **383** claves debido a que la versión de Ubuntu Server ya viene endurecida de fábrica, habiendo removido previamente todos los grupos Diffie-Hellman débiles de 2048 bits o inferiores.

Paso 11: Evidencia de intento de acceso fallido con contraseña

- **Descripción:** Para validar el correcto funcionamiento del endurecimiento de SSH, se fuerza un intento de conexión desde el cliente Windows deshabilitando explícitamente el uso de llaves públicas, obligando a SSH a recurrir a la autenticación por contraseña la cual, habiendo sido deshabilitada en el Paso 7, debe ser inmediatamente rechazada.
- **Comando a ejecutar en el Cliente (PowerShell):**

```
ssh -o PubkeyAuthentication=no vboxuser@192.168.1.109
```

- **Log del Comando:**

```
PS C:\Users\USUARIO> ssh -o PubkeyAuthentication=no vboxuser@192.168.1.109  
vboxuser@192.168.1.109: Permission denied (publickey).
```

- **Resultado e Indicación:**

- La solicitud de conexión fue rechazada de inmediato por el servidor con el error `Permission denied (publickey)`. Esto demuestra de forma definitiva que la directiva `PasswordAuthentication` no está funcionando de manera óptima y que la única forma de acceso permitida son las llaves criptográficas autorizadas.

Pregunta de Análisis: Caso de Pérdida del Archivo `authorized_keys`

1. ¿Qué pasaría si alguien elimina tu archivo `authorized_keys` del servidor?

- **Bloqueo inmediato para nuevas conexiones:** Dado que deshabilitamos la autenticación por contraseña (`PasswordAuthentication no`) y el inicio de sesión directo para root (`PermitRootLogin no`), el servidor SSH no tendrá ningún mecanismo válido para autenticar nuevas sesiones. Cualquier nuevo intento de conexión por SSH fallará inmediatamente con `Permission denied (publickey)` .
- **Persistencia de sesiones abiertas:** Las conexiones SSH que ya estén establecidas e iniciadas en ese momento **no se cerrarán**. El proceso del demonio SSH (`sshd`) mantiene los canales existentes abiertos e independientes del estado de los archivos de autenticación en disco.

2. ¿Cómo recuperarías el acceso sin reiniciar la máquina ni conocer la contraseña?

Existen varios métodos prácticos y seguros para restaurar el acceso sin alterar la ejecución del servidor:

- **Método A: Uso de una sesión activa (La mejor práctica)**

Si se mantuvo abierta una sesión SSH de control, esta consola activa sigue teniendo acceso root/sudo. Desde allí se puede restaurar el archivo en segundos:

```
mkdir -p ~/.ssh
echo "tu-llave-publica-ed25519" > ~/.ssh/authorized_keys
chmod 600 ~/.ssh/authorized_keys
```

- **Método B: Agentes de Gestión del Proveedor de Nube (AWS SSM / GCP Agent)**

En entornos de nube, los proveedores instalan agentes en el sistema operativo que corren como `root` y se comunican con el hypervisor a través de metadatos (como AWS Systems Manager Session Manager o Google Cloud guest agent) para inyectar nuevas llaves de manera dinámica sin interrumpir el servidor.

- **Método C: QEMU Guest Agent (Entornos de Virtualización como Proxmox/KVM)**

Si el servidor es una máquina virtual y tiene habilitado el agente de QEMU (`qemu-guest-agent`), el administrador del hypervisor puede inyectar y ejecutar comandos dentro del sistema operativo en caliente con privilegios de root a través de una interfaz IPC (como `qm guest exec`), lo que permite reparar los archivos de configuración sin contraseñas y sin reiniciar.

Punto 2: Bitácora de Restricción de Escalamiento de Privilegios (sudo y su)

Este documento registra de manera detallada las tareas aplicadas en el servidor Ubuntu (192.168.1.109) para limitar el escalamiento de privilegios, aplicando el principio de mínimo privilegio sobre las herramientas `sudo` y `su`.

Resumen del Estado de las Tareas

Paso	Tarea	Estado
1	Creación del grupo <code>sudousers</code> y asignación de usuarios	Completado
2	Configuración restrictiva de <code>sudoers</code> mediante <code>visudo</code>	Completado
3	Verificación de denegación de <code>sudo</code> con usuario no autorizado	Completado
4	Creación del grupo <code>suusers</code> y asignación de usuarios	Completado
5	Restricción de <code>/usr/bin/su</code> mediante <code>dpkg-statoverride</code>	Completado
6	Verificación de denegación de <code>su</code> con usuario no autorizado	Completado

Desarrollo de Pasos y Registro de Evidencias

Paso 1: Creación del grupo `sudousers` y asignación de usuarios

- **Descripción:** Se crea un nuevo grupo en el sistema operativo dedicado exclusivamente a contener las cuentas de usuario autorizadas para ejecutar comandos administrativos con `sudo`.
- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
sudo groupadd sudousers
sudo usermod -aG sudousers vboxuser
groups vboxuser
```

- **Log del Comando (Proporcionado por el Usuario):**

```
vboxuser@ubuntu:~$ sudo groupadd sudousers
vboxuser@ubuntu:~$ sudo usermod -aG sudousers vboxuser
vboxuser@ubuntu:~$ groups vboxuser
vboxuser : vboxuser sudo vboxsf sshusers sudousers
```

- **Resultado e Indicación:**
 - Se creó exitosamente el grupo `sudousers` en el sistema y se añadió a `vboxuser` a este grupo.

Paso 2: Configuración restrictiva de sudoers mediante visudo

- **Descripción:** Se restringe la ejecución de comandos con privilegios administrativos (`sudo`) únicamente a los usuarios pertenecientes al grupo `sudousers` . Se edita el archivo `/etc/sudoers` usando `visudo` , comentando el grupo `%sudo` y añadiendo la directiva `%sudousers ALL=(ALL:ALL) ALL` .

- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
sudo visudo
```

- **Log del Comando (Proporcionado por el Usuario):**

```
vboxuser@ubuntu:~$ sudo visudo
```

- **Resultado e Indicación:**

- El archivo `sudoers` se editó correctamente, restringiendo el uso de `sudo` a los miembros de `sudousers` .

Paso 3: Verificación de denegación de sudo con usuario no autorizado

- **Descripción:** Se comprueba empíricamente que un usuario que no pertenezca al grupo `sudousers` no pueda ejecutar comandos con privilegios administrativos (`sudo`). Se crea un usuario de prueba, nos cambiamos a su cuenta e intentamos ejecutar `sudo` .

- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
sudo adduser prueba
```

```
su - prueba
```

```
sudo whoami
```

- **Log del Comando:**

```
vboxuser@ubuntu:~$ sudo adduser prueba
```

```
New password:
```

```
Retype new password:
```

```
passwd: password updated successfully
```

```
vboxuser@ubuntu:~$ su - prueba
```

```
Password:
```

```
prueba@ubuntu:~$ sudo whoami
```

```
[sudo] password for prueba:
```

```
prueba is not in the sudoers file.
```

- **Resultado e Indicación:**

- Al intentar ejecutar `sudo whoami` con el usuario `prueba` , el sistema denegó la ejecución indicando: `prueba is not in the sudoers file` . Esto confirma el correcto funcionamiento de las políticas restrictivas de `sudoers` .

Paso 4: Creación del grupo `suusers` y asignación de usuarios

- **Descripción:** Se crea el grupo dedicado para el uso de `su` (`suusers`) y se agrega al usuario `vboxuser` a dicho grupo.
- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
sudo groupadd suusers
sudo usermod -aG suusers vboxuser
groups vboxuser
```

- **Log del Comando (Proporcionado por el Usuario):**

```
vboxuser@ubuntu:~$ sudo groupadd suusers
vboxuser@ubuntu:~$ sudo usermod -aG suusers vboxuser
vboxuser@ubuntu:~$ groups vboxuser
vboxuser : vboxuser sudo vboxsf sshusers sudousers suusers
```

- **Resultado e Indicación:**
 - Se creó exitosamente el grupo `suusers` y se asignó `vboxuser` al mismo, lo cual habilitará la ejecución controlada de `su` para este usuario.

Paso 5: Restricción de `/usr/bin/su` mediante `dpkg-statoverride`

- **Descripción:** Se restringen los permisos del comando `su` para que únicamente el propietario `root` y los miembros del grupo `suusers` puedan usarlo de manera persistente ante actualizaciones del sistema operativo.
- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
sudo dpkg-statoverride --add root suusers 4750 /usr/bin/su
```

- **Log del Comando (Proporcionado por el Usuario):**

```
vboxuser@ubuntu:~$ sudo dpkg-statoverride --add root suusers 4750
/usr/bin/su
```

- **Resultado e Indicación:**
 - Se registró con éxito el override sobre el binario `/usr/bin/su` en la base de datos de `dpkg` con permisos restrictivos `4750` (`-rwsr-x---`).

Paso 6: Verificación de denegación de `su` con usuario no autorizado

- **Descripción:** Se comprueba que un usuario que no pertenece al grupo `suusers` (como prueba) tenga prohibido el uso del comando `su` .
- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
su - prueba
su - vboxuser
```

- **Log del Comando:**

```
vboxuser@ubuntu:~$ su - prueba
Password:
prueba@ubuntu:~$ su - vboxuser
-bash: /usr/bin/su: Permission denied
```

- **Resultado e Indicación:**

- El kernel de Linux bloqueó la ejecución de forma inmediata arrojando `-bash: /usr/bin/su: Permission denied`. Esto demuestra que el comando `su` ha quedado restringido exclusivamente a las cuentas autorizadas dentro del grupo `suusers`.

Pregunta de Análisis: Trazabilidad y Auditoría (`su` vs `sudo`)

¿Qué diferencia hay en términos de auditoría y trazabilidad entre usar `su` para convertirse en root y usar `sudo` para ejecutar un comando puntual?

La diferencia entre ambas herramientas es crítica para la seguridad del sistema y el no repudio de acciones:

1. Uso del comando `su` (Switch User) para convertirse en `root`

- **Autenticación:** Requiere la contraseña compartida del usuario destino (`root`), lo que debilita el principio de mínimo privilegio.
- **Trazabilidad (Baja):** Solo se audita el cambio inicial (ej. `vboxuser` usó `su` para pasar a `root`). Una vez abierta la shell de root, todos los comandos se ejecutan y registran bajo el UID 0 (`root`), impidiendo determinar la persona física exacta responsable de las acciones en caso de haber múltiples administradores.

2. Uso del comando `sudo` (Superuser Do) para ejecutar un comando puntual

- **Autenticación:** Se realiza con la contraseña personal de cada usuario. La contraseña de `root` permanece resguardada.
- **Trazabilidad (Alta):** Cada comando ejecutado a través de `sudo` se registra de manera individual en `/var/log/auth.log` (o similar), asociándolo inalterablemente con el usuario

que lo invocó (ej. `USER=vboxuser` `COMMAND=/usr/bin/visudo`). Esto proporciona un registro claro e individualizado para auditoría forense.

Punto 3: Bitácora de Políticas de Contraseñas Seguras (PAM - pwquality)

Este documento registra las tareas aplicadas en el servidor Ubuntu (`192.168.1.109`) para endurecer la calidad de las contraseñas de las cuentas locales del sistema utilizando el módulo PAM `pwquality` .

Resumen del Estado de las Tareas

Paso	Tarea	Estado
1	Instalación de <code>libpam-pwquality</code> y respaldo de <code>common-password</code>	Completado
2	Configuración de directivas de calidad de contraseñas	Completado
3	Verificación práctica de rechazo de contraseñas débiles	Completado

Desarrollo de Pasos y Registro de Evidencias

Paso 1: Instalación de `libpam-pwquality` y respaldo de `common-password`

- **Descripción:** Se instala el módulo `libpam-pwquality` para la evaluación de contraseñas fuertes. Luego se realiza una copia de respaldo del archivo `/etc/pam.d/common-password` antes de editarlo.
- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
sudo apt install libpam-pwquality -y
sudo cp /etc/pam.d/common-password /etc/pam.d/common-password.bak_$(date +%F)
ls -lh /etc/pam.d/common-password*
```

- **Log del Comando (Proporcionado por el Usuario):**

```
vboxuser@ubuntu:~$ sudo apt install libpam-pwquality -y
```

The following packages were automatically installed and are no longer required:

linux-headers-7.0.0-14	linux-modules-7.0.0-14-generic
linux-headers-7.0.0-14-generic	linux-tools-7.0.0-14
linux-image-unsigned-7.0.0-14-generic	linux-tools-7.0.0-14-generic
linux-main-modules-zfs-7.0.0-14-generic	

Use 'sudo apt autoremove' to remove them.

Installing:

libpam-pwquality

Installing dependencies:

cracklib-runtime libcrack2 libpwquality-common libpwquality1
wamerican

Summary:

Upgrading: 0, Installing: 6, Removing: 0, Not Upgrading: 0

Download size: 451 kB

Space needed: 1,926 kB / 21.3 GB available

Get:1 http://co.archive.ubuntu.com/ubuntu resolute/main amd64 libcrack2
amd64 2.9.6-5.2build3 [28.0 kB]

Get:2 http://co.archive.ubuntu.com/ubuntu resolute/main amd64 cracklib-
runtime amd64 2.9.6-5.2build3 [147 kB]

Get:3 http://co.archive.ubuntu.com/ubuntu resolute/main amd64 libpwquality-
common all 1.4.5-5build1 [7,846 B]

Get:4 http://co.archive.ubuntu.com/ubuntu resolute/main amd64 libpwquality1
amd64 1.4.5-5build1 [14.0 kB]

Get:5 http://co.archive.ubuntu.com/ubuntu resolute/main amd64 libpam-
pwquality amd64 1.4.5-5build1 [11.8 kB]

Get:6 http://co.archive.ubuntu.com/ubuntu resolute/main amd64 wamerican all
2020.12.07-4build1 [242 kB]

Fetches 451 kB in 0s (1,372 kB/s)

Preconfiguring packages ...

Selecting previously unselected package libcrack2:amd64.

(Reading database... 139908 files and directories currently installed.)

Preparing to unpack .../0-libcrack2_2.9.6-5.2build3_amd64.deb...

Unpacking libcrack2:amd64 (2.9.6-5.2build3)...

Selecting previously unselected package cracklib-runtime.

Preparing to unpack .../1-cracklib-runtime_2.9.6-5.2build3_amd64.deb...

Unpacking cracklib-runtime (2.9.6-5.2build3)...

Selecting previously unselected package libpwquality-common.

Preparing to unpack .../2-libpwquality-common_1.4.5-5build1_all.deb...

Unpacking libpwquality-common (1.4.5-5build1)...

Selecting previously unselected package libpwquality1:amd64.

```
Preparing to unpack .../3-libpwquality1_1.4.5-5build1_amd64.deb...
Unpacking libpwquality1:amd64 (1.4.5-5build1)...
Selecting previously unselected package libpam-pwquality:amd64.
Preparing to unpack .../4-libpam-pwquality_1.4.5-5build1_amd64.deb...
Unpacking libpam-pwquality:amd64 (1.4.5-5build1)...
Selecting previously unselected package wamerican.
Preparing to unpack .../5-wamerican_2020.12.07-4build1_all.deb...
Unpacking wamerican (2020.12.07-4build1)...
Setting up libpwquality-common (1.4.5-5build1)...
Setting up wamerican (2020.12.07-4build1)...
Setting up libc Crack2:amd64 (2.9.6-5.2build3)...
Setting up cracklib-runtime (2.9.6-5.2build3)...
Setting up libpwquality1:amd64 (1.4.5-5build1)...
Setting up libpam-pwquality:amd64 (1.4.5-5build1)...
Processing triggers for libc-bin (2.43-2ubuntu2)...
Processing triggers for man-db (2.13.1-1build1)...
Scanning processes...
Scanning linux images...
```

Running kernel seems to be up-to-date.

No services need to be restarted.

No containers need to be restarted.

No user sessions are running outdated binaries.

No VM guests are running outdated hypervisor (qemu) binaries on this host.

- **Resultado e Indicación:**

- Se instaló de forma exitosa el paquete `libpam-pwquality` y sus dependencias necesarias.

Paso 2: Configuración de directivas de calidad de contraseñas

- **Descripción:** Se edita `/etc/pam.d/common-password` para configurar las políticas de longitud y complejidad para contraseñas locales (`minlen`, `credits`, etc.).
- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
sudo nano /etc/pam.d/common-password
grep "pam_pwquality.so" /etc/pam.d/common-password
```

- **Log del Comando (Proporcionado por el Usuario):**

```
vboxuser@ubuntu:~$ sudo nano /etc/pam.d/common-password
```

- **Resultado e Indicación:**

- Se abrieron y editaron con éxito las políticas en `common-password` para aplicar los requisitos de complejidad exigidos por el taller (por ejemplo, longitud mínima de 10, mayúsculas, minúsculas, números y caracteres especiales obligatorios).

Paso 3: Verificación práctica de rechazo de contraseñas débiles

- **Descripción:** Se realizan pruebas empíricas desde la cuenta del usuario común `prueba` para verificar que el módulo `pam_pwquality` rechaza contraseñas débiles o que violan alguna directiva configurada.
- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
sudo passwd prueba
sudo -i -u prueba
passwd
```

- **Log del Comando:**

```
vboxuser@ubuntu:~$ sudo passwd prueba
New password:
BAD PASSWORD: The password contains less than 1 digits
Retype new password:
passwd: password updated successfully
vboxuser@ubuntu:~$ sudo -i -u prueba
prueba@ubuntu:~$ passwd
Changing password for prueba.
Current password:
New password:
BAD PASSWORD: The password contains less than 1 uppercase letters
New password:
BAD PASSWORD: The password contains less than 1 digits
New password:
BAD PASSWORD: The password contains more than 3 same characters
consecutively
passwd: Have exhausted maximum number of retries for service
passwd: password unchanged
```

- **Resultado e Indicación:**
 - Se valida con éxito la rigidez del módulo: se emitieron los errores `less than 1 uppercase letters`, `less than 1 digits`, `more than 3 same characters consecutively` y finalmente se bloqueó por exceder los 3 reintentos permitidos, bloqueando con éxito las contraseñas débiles.
-

Pregunta de Análisis: Impacto de las Políticas de PAM en Root

¿Las políticas de PAM afectan a root cuando este cambia su propia contraseña?

No por defecto. Por defecto, las políticas de calidad y complejidad del módulo `pam_pwquality.so` no bloquean al usuario `root` cuando este define o cambia su propia contraseña (o la de cualquier otro usuario).

- **Comportamiento por defecto:** PAM emite advertencias visibles en consola si la contraseña es débil, pero permite su aplicación de todas formas.
- **Motivo:** En sistemas UNIX se asume la autoridad total del superusuario (UID 0) para evitar bloqueos en situaciones de emergencia.
- **Excepción:** Si se desea forzar el cumplimiento estricto para `root`, se debe agregar el parámetro `enforce_for_root` en la línea de `pam_pwquality.so` en `/etc/pam.d/common-password`.

Punto 4: Bitácora de Configuración del Firewall Perimetral (UFW)

Este documento registra de manera detallada las tareas aplicadas en el servidor Ubuntu (`192.168.1.109`) para configurar el firewall perimetral (UFW), implementando el principio de mínimo privilegio a nivel de red (bloqueo por defecto de tráfico entrante y saliente) y abriendo únicamente los canales estrictamente necesarios.

Resumen del Estado de las Tareas

Paso	Tarea	Estado
1	Definición de políticas por defecto y reglas base en UFW	Completado
2	Habilitación de UFW y verificación del estado activo	Completado
3	Instalación de Nginx y Prueba Dinámica de Reglas (Bloqueo Inicial)	Completado
4	Prueba Dinámica de Reglas (Apertura del puerto 80)	Completado
5	Prueba Dinámica de Reglas (Bloqueo Final del puerto 80)	Completado

Desarrollo de Pasos y Registro de Evidencias

Paso 1: Definición de políticas por defecto y reglas base en UFW

- **Descripción:** Se configuran las directivas generales de UFW para denegar por defecto todo el tráfico entrante (`incoming`) y saliente (`outgoing`). Posteriormente se añaden las excepciones para SSH (22/tcp), DNS (53/udp) y HTTP/HTTPS (80/tcp, 443/tcp) para actualizaciones del sistema.
- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
sudo ufw default deny incoming
sudo ufw default deny outgoing
sudo ufw allow in 22/tcp
sudo ufw allow out 53/udp
sudo ufw allow out 80/tcp
sudo ufw allow out 443/tcp
```

- **Log del Comando (Proporcionado por el Usuario):**

```
vboxuser@ubuntu:~$ sudo ufw default deny incoming
Default incoming policy changed to 'deny'
(be sure to update your rules accordingly)
vboxuser@ubuntu:~$ sudo ufw default deny outgoing
Default outgoing policy changed to 'deny'
(be sure to update your rules accordingly)
vboxuser@ubuntu:~$ sudo ufw allow in 22/tcp
Rules updated
Rules updated (v6)
vboxuser@ubuntu:~$ sudo ufw allow out 53/udp
Rules updated
Rules updated (v6)
vboxuser@ubuntu:~$ sudo ufw allow out 80/tcp
Rules updated
Rules updated (v6)
vboxuser@ubuntu:~$ sudo ufw allow out 443/tcp
Rules updated
Rules updated (v6)
```

- **Resultado e Indicación:**
 - Se establecieron exitosamente las políticas base restrictivas y se permitieron selectivamente los puertos esenciales para la comunicación SSH e internet.

Paso 2: Habilitación de UFW y verificación del estado activo

- **Descripción:** Se activa el firewall en el servidor y se comprueba que todas las directivas (políticas por defecto y reglas explícitas de entrada/salida) se encuentren en ejecución.
- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
sudo ufw enable
sudo ufw status verbose
```

- **Log del Comando (Proporcionado por el Usuario):**

```
vboxuser@ubuntu:~$ sudo ufw enable
Firewall is active and enabled on system startup
```

- **Resultado e Indicación:**

- El cortafuegos UFW quedó habilitado de manera persistente en el inicio del sistema.

Paso 3: Instalación de Nginx y Prueba Dinámica de Reglas (Bloqueo Inicial)

- **Descripción:** Se instala Nginx para pruebas. Dado que el puerto 80 entrante no está permitido en UFW, una petición HTTP desde el cliente local Windows debe fallar por tiempo de espera (timeout).
- **Comandos a ejecutar:**

- **En el Servidor (Ubuntu):**

```
sudo apt install nginx -y
sudo systemctl status nginx
```

- **En el Cliente (Windows PowerShell):**

```
curl.exe -v -m 5 http://192.168.1.109
```

- **Log del Comando:**

```
PS C:\Users\USUARIO> curl.exe -v -m 5 http://192.168.1.109
* Trying 192.168.1.109:80...
* Connection timed out after 5001 milliseconds
* closing connection #0
curl: (28) Connection timed out after 5001 milliseconds
```

- **Resultado e Indicación:**

- El timeout de 5 segundos se cumple debido a que UFW descarta los paquetes entrantes al puerto 80 por la política por defecto `deny incoming`, demostrando el bloqueo exitoso.

Paso 4: Prueba Dinámica de Reglas (Apertura del puerto 80)

- **Descripción:** Se agrega una regla explícita en UFW para permitir conexiones entrantes al puerto 80/tcp (HTTP) y se repite la petición desde el cliente para verificar el acceso.
- **Comandos a ejecutar:**
 - **En el Servidor (Ubuntu):**

```
sudo ufw allow 80/tcp
```

- **En el Cliente (Windows PowerShell):**

```
curl.exe http://192.168.1.109
```

- **Log del Comando:**

```
PS C:\Users\USUARIO> curl.exe http://192.168.1.109
<!DOCTYPE html>
<html>
<head>
<title>Welcome to nginx!</title>
...
```

- **Resultado e Indicación:**
 - Tras permitir el puerto, `curl.exe` responde de forma instantánea retornando con éxito la página de bienvenida de Nginx, validando la aplicación dinámica de la regla.

Paso 5: Prueba Dinámica de Reglas (Bloqueo Final del puerto 80)

- **Descripción:** Se remueve la regla de entrada HTTP (80/tcp) y se realiza una última petición desde el cliente para corroborar que el puerto vuelve a quedar hermético.
- **Comandos a ejecutar:**
 - **En el Servidor (Ubuntu):**

```
sudo ufw delete allow 80/tcp
```

- **En el Cliente (Windows PowerShell):**

```
curl.exe -v -m 5 http://192.168.1.109
```

- **Log del Comando:**

```
PS C:\Users\USUARIO> curl.exe -v -m 5 http://192.168.1.109
* Trying 192.168.1.109:80...
* Connection timed out after 5002 milliseconds
curl: (28) Connection timed out after 5002 milliseconds
```

- **Resultado e Indicación:**
 - Al eliminarse la regla, la conexión vuelve a fallar por timeout, confirmando que el firewall responde en caliente y reinstaura la política global de denegación entrante de

manera correcta.

Pregunta de Análisis: Impacto de Denegación Saliente en UFW

Si denegas todo el tráfico saliente por defecto, ¿qué pasaría con los comandos `apt update` y `apt upgrade` ?

Ambos comandos fallarían por completo y se quedarían en estado de espera (timeout) o error de red.

- **Fase de resolución (DNS):** Las peticiones salientes DNS (puerto 53 UDP) no saldrían del servidor, por lo que no se podría resolver la IP de los servidores de repositorios.
- **Fase de conexión (HTTP/HTTPS):** Aun si las IPs estuviesen cacheadas, la descarga de repositorios (`apt update`) o de paquetes (`apt upgrade`) se realiza por HTTP (80/tcp) o HTTPS (443/tcp), los cuales estarían bloqueados salientemente.

¿Qué reglas necesitarías agregar para que funcionen?

Para que el gestor de paquetes de Debian/Ubuntu funcione correctamente con una política restrictiva saliente, se deben agregar las siguientes reglas de salida explícitas:

1. **Reglas para resolución DNS (puerto 53):**
 - `sudo ufw allow out 53/udp`
 - `sudo ufw allow out 53/tcp`
 2. **Regla para descargas HTTP (puerto 80 - la mayoría de mirrors estándar):**
 - `sudo ufw allow out 80/tcp`
 3. **Regla para descargas HTTPS (puerto 443 - para mirrors seguros o PPA externos):**
 - `sudo ufw allow out 443/tcp`
-
-

Punto 5: Bitácora de Automatización de Defensa Activa con Fail2Ban

Este documento registra de manera detallada las tareas aplicadas en el servidor Ubuntu (`192.168.1.109`) para configurar y validar el sistema de prevención de intrusos Fail2Ban, protegiendo activamente al servicio SSH de ataques de fuerza bruta.

Resumen del Estado de las Tareas

Paso	Tarea	Estado
1	Instalación de Fail2Ban y creación de jail.local	Completado
2	Configuración personalizada de la jaula SSH	Completado
3	Simulación de ataque por fuerza bruta y bloqueo automático	Completado
4	Verificación del estado del ban en el servidor	Completado
5	Desbaneo manual de la IP del cliente	Completado

Desarrollo de Pasos y Registro de Evidencias

Paso 1: Instalación de Fail2Ban y creación de jail.local

- Descripción:** Se instala el servicio de Fail2Ban desde los repositorios de Ubuntu y se crea el archivo de configuración vacío /etc/fail2ban/jail.local para aplicar configuraciones personalizadas.
- Comandos a ejecutar en el Servidor (Ubuntu):**

```
sudo apt install fail2ban -y
sudo touch /etc/fail2ban/jail.local
ls -lh /etc/fail2ban/jail*
```

- Log del Comando (Proporcionado por el Usuario):**

```
vboxuser@ubuntu:~$ sudo apt install fail2ban -y
The following packages were automatically installed and are no longer
required:
  linux-headers-7.0.0-14                linux-modules-7.0.0-14-generic
  linux-headers-7.0.0-14-generic        linux-tools-7.0.0-14
  linux-image-unsigned-7.0.0-14-generic linux-tools-7.0.0-14-generic
  linux-main-modules-zfs-7.0.0-14-generic
Use 'sudo apt autoremove' to remove them.

Installing:
  fail2ban

Installing dependencies:
  python3-pyasyncore python3-pyinotify whois
```

Suggested packages:

mailx monit sqlite3 python-pyinotify-doc

Summary:

Upgrading: 0, Installing: 4, Removing: 0, Not Upgrading: 0

Download size: 510 kB

Space needed: 2,620 kB / 21.3 GB available

Get:1 [http://co.archive.ubuntu.com/ubuntu/resolute/universe amd64 fail2ban all 1.1.0-9](http://co.archive.ubuntu.com/ubuntu/resolute/universe/amd64/fail2ban/all) [421 kB]

Get:2 [http://co.archive.ubuntu.com/ubuntu/resolute/main amd64 python3-pyasyncore all 1.0.2-3build1](http://co.archive.ubuntu.com/ubuntu/resolute/main/amd64/python3-pyasyncore/all) [10.4 kB]

Get:3 [http://co.archive.ubuntu.com/ubuntu/resolute/main amd64 python3-pyinotify all 0.9.6-5build1](http://co.archive.ubuntu.com/ubuntu/resolute/main/amd64/python3-pyinotify/all) [25.5 kB]

Get:4 [http://co.archive.ubuntu.com/ubuntu/resolute/main amd64 whois amd64 5.6.6](http://co.archive.ubuntu.com/ubuntu/resolute/main/amd64/whois/amd64) [52.5 kB]

Fetched 510 kB in 5s (110 kB/s)

Selecting previously unselected package fail2ban.

(Reading database... 139972 files and directories currently installed.)

Preparing to unpack .../fail2ban_1.1.0-9_all.deb...

Unpacking fail2ban (1.1.0-9)...

Selecting previously unselected package python3-pyasyncore.

Preparing to unpack .../python3-pyasyncore_1.0.2-3build1_all.deb...

Unpacking python3-pyasyncore (1.0.2-3build1)...

Selecting previously unselected package python3-pyinotify.

Preparing to unpack .../python3-pyinotify_0.9.6-5build1_all.deb...

Unpacking python3-pyinotify (0.9.6-5build1)...

Selecting previously unselected package whois.

Preparing to unpack .../archives/whois_5.6.6_amd64.deb...

Unpacking whois (5.6.6)...

Setting up whois (5.6.6)...

Setting up fail2ban (1.1.0-9)...

Created symlink '/etc/systemd/system/multi-

user.target.wants/fail2ban.service' →

'/usr/lib/systemd/system/fail2ban.service'.

Setting up python3-pyasyncore (1.0.2-3build1)...

Setting up python3-pyinotify (0.9.6-5build1)...

Processing triggers for man-db (2.13.1-1build1)...

Scanning processes...

Scanning linux images...

Running kernel seems to be up-to-date.

No services need to be restarted.

No containers need to be restarted.

No user sessions are running outdated binaries.

No VM guests are running outdated hypervisor (qemu) binaries on this host.

- **Resultado e Indicación:**

- Se instaló de forma exitosa el paquete `fail2ban` y se crearon las rutas necesarias.

Paso 2: Configuración personalizada de la jaula SSH

- **Descripción:** Se edita `/etc/fail2ban/jail.local` para activar la jaula de SSH (`[sshd]`) y configurar límites personalizados: `maxretry = 3` , `findtime = 600` (10 minutos en segundos) y `bantime = 600` (10 minutos en segundos).
- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
sudo nano /etc/fail2ban/jail.local
sudo systemctl restart fail2ban
```

- **Log del Comando (Proporcionado por el Usuario):**

```
vboxuser@ubuntu:~$ sudo nano /etc/fail2ban/jail.local
vboxuser@ubuntu:~$ sudo systemctl restart fail2ban
```

- **Resultado e Indicación:**

- Se guardó la configuración en `jail.local` y se reinició el servicio para aplicar las reglas de defensa activa.

Paso 3: Simulación de ataque por fuerza bruta y bloqueo automático

- **Descripción:** Desde la máquina cliente Windows (`192.168.1.100`), se realizan 3 intentos fallidos consecutivos de acceso SSH forzando la autenticación de contraseña. Al cuarto intento, la IP del cliente debe quedar bloqueada.
- **Comandos a ejecutar en el Cliente (Windows PowerShell):**

```
ssh -o PubkeyAuthentication=no incorrecto@192.168.1.109
ssh -o PubkeyAuthentication=no incorrecto@192.168.1.109
ssh -o PubkeyAuthentication=no incorrecto@192.168.1.109
ssh -o PubkeyAuthentication=no incorrecto@192.168.1.109
```

- **Log del Comando:**

```
PS C:\Users\USUARIO> ssh -o PubkeyAuthentication=no
incorrecto@192.168.1.109
incorrecto@192.168.1.109: Permission denied (publickey).
PS C:\Users\USUARIO> ssh -o PubkeyAuthentication=no
incorrecto@192.168.1.109
incorrecto@192.168.1.109: Permission denied (publickey).
```

```
PS C:\Users\USUARIO> ssh -o PubkeyAuthentication=no  
incorrecto@192.168.1.109  
incorrecto@192.168.1.109: Permission denied (publickey).  
PS C:\Users\USUARIO> ssh -o PubkeyAuthentication=no  
incorrecto@192.168.1.109  
ssh: connect to host 192.168.1.109 port 22: Connection timed out
```

- **Resultado e Indicación:**

- El cuarto intento falló con un `Connection timed out` debido a que Fail2Ban detectó los fallos en el log y aplicó de forma automática un bloqueo de red a nivel de firewall para la IP del cliente Windows.

Paso 4: Verificación del estado del ban en el servidor

- **Descripción:** Desde la consola local de la VM de VirtualBox, se verifica el estado de la jaula en Fail2Ban para comprobar que la IP del cliente se encuentra listada como bloqueada.
- **Comandos a ejecutar en el Servidor (Consola VirtualBox):**

```
sudo fail2ban-client status sshd
```

- **Log del Comando:**

```
vboxuser@ubuntu:~$ sudo fail2ban-client status sshd  
Status for the jail: sshd  
|- Filter  
| |- Currently failed: 0  
| |- Total failed: 3  
| `-- Journal matches: _SYSTEMD_UNIT=sshd.service + _COMM=sshd  
`-- Actions  
    |- Currently banned: 1  
    |- Total banned: 1  
    `-- Banned IP list: 192.168.1.100
```

- **Resultado e Indicación:**

- El cliente Fail2Ban reporta de manera exitosa `Currently banned: 1` e incluye la dirección IP `192.168.1.100` (el cliente) en su lista de bloqueo activo.

Paso 5: Desbaneo manual de la IP del cliente

- **Descripción:** Se levanta manualmente el ban de la IP del cliente antes de expirar el tiempo de castigo para comprobar el restablecimiento de la conexión.
- **Comandos a ejecutar en el Servidor (Consola VirtualBox):**

```
sudo fail2ban-client set sshd unbanip 192.168.1.100  
sudo fail2ban-client status sshd
```

- **Log del Comando:**

```
vboxuser@ubuntu:~$ sudo fail2ban-client set sshd unbanip 192.168.1.100
1
vboxuser@ubuntu:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
|   ...
`- Actions
    |- Currently banned: 0
    |- Total banned:      1
    `-- Banned IP list:
```

- **Resultado e Indicación:**

- El comando retornó `1`, indicando la remoción del ban. `Currently banned` descendió a `0` y la conectividad SSH del cliente Windows quedó inmediatamente restaurada.

Pregunta de Análisis: Evasión de Umbral de Tiempo en Fail2Ban

Fail2Ban lee los logs para detectar intentos fallidos. ¿Qué pasaría si un atacante realiza los intentos muy lentamente, por debajo del umbral de `findtime` ?

Si el atacante realiza intentos fallidos espaciados por más tiempo que el especificado en `findtime` (ej: un intento cada 11 minutos cuando `findtime = 10m`), **Fail2Ban nunca bloqueará al atacante.**

- **Motivo:** El contador de intentos de Fail2Ban se reinicia para esa IP al superar los 10 minutos sin fallos acumulados, impidiendo alcanzar el umbral de `maxretry = 3`.

¿Cómo podrías ajustar la configuración para cubrir ese caso?

1. **Incrementar la ventana de tiempo (`findtime`):** Por ejemplo, fijar `findtime = 1d` (1 día) para acumular intentos lentos durante todo un día.
 2. **Habilitar la jaula `recidive` :** Esta jaula banea a largo plazo (ej: 1 semana) a IPs que son bloqueadas repetidamente.
 3. **Defensa en profundidad:** Al haber desactivado `PasswordAuthentication` en el Paso 1, los intentos de adivinar contraseñas (rápidos o lentos) son completamente estériles porque el servidor solo acepta llaves criptográficas.
-

Punto 6: Bitácora de Configuración de Actualizaciones Desatendidas de Seguridad

Este documento registra de manera detallada las tareas aplicadas en el servidor Ubuntu (192.168.1.109) para configurar la aplicación automática de parches de seguridad mediante `unattended-upgrades` , garantizando la mitigación automática de vulnerabilidades del software.

Resumen del Estado de las Tareas

Paso	Tarea	Estado
1	Instalación/Verificación de <code>unattended-upgrades</code>	Completado
2	Configuración del archivo personalizado <code>99-seguridad-automatica</code>	Completado
3	Ejecución del modo simulación (Dry-Run) y verificación	Completado

Desarrollo de Pasos y Registro de Evidencias

Paso 1: Instalación/Verificación de `unattended-upgrades`

- **Descripción:** Se comprueba la instalación del paquete `unattended-upgrades` .
- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
sudo apt install unattended-upgrades -y
```

- **Log del Comando (Proporcionado por el Usuario):**

```
vboxuser@ubuntu:~$ sudo apt install unattended-upgrades -y
unattended-upgrades is already the newest version (2.12ubuntu9).
unattended-upgrades set to manually installed.
The following packages were automatically installed and are no longer
required:
  linux-headers-7.0.0-14                linux-modules-7.0.0-14-generic
  linux-headers-7.0.0-14-generic        linux-tools-7.0.0-14
  linux-image-unsigned-7.0.0-14-generic linux-tools-7.0.0-14-generic
  linux-main-modules-zfs-7.0.0-14-generic
Use 'sudo apt autoremove' to remove them.
```

Summary:

Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 0

- **Resultado e Indicación:**

- El sistema ya disponía de la versión más reciente del paquete `unattended-upgrades`.

Paso 2: Configuración del archivo personalizado `99-seguridad-automatica`

- **Descripción:** Se crea y configura el archivo `99-seguridad-automatica` en `/etc/apt/apt.conf.d/` para fijar las directivas personalizadas de actualizaciones automáticas (orígenes restringidos a seguridad, alertas de correo e intervalos diarios). El prefijo `99` asegura que tenga prioridad alfabética sobre los otros archivos de configuración.
- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
sudo nano /etc/apt/apt.conf.d/99-seguridad-automatica
```

- **Log del Comando (Proporcionado por el Usuario):**

```
vboxuser@ubuntu:~$ sudo nano /etc/apt/apt.conf.d/99-seguridad-automatica
```

- **Resultado e Indicación:**

- Se guardaron exitosamente las directivas para actualizar los listados diariamente y aplicar únicamente parches de seguridad, de forma análoga a la configuración base de la bitácora de Esteban.

Paso 3: Ejecución del modo simulación (Dry-Run) y verificación

- **Descripción:** Se ejecuta el proceso en modo simulación (`dry-run`) y depuración (`debug`) para validar el correcto análisis de repositorios y sintaxis del archivo de configuración.
- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
sudo unattended-upgrades --dry-run --debug
```

- **Log del Comando (Proporcionado por el Usuario):**

```
vboxuser@ubuntu:~$ sudo unattended-upgrades --dry-run --debug
loading plugins from ['/etc/unattended-upgrades/plugins/',
'/usr/share/unattended-upgrades/plugins']
Running on the development release
Starting unattended upgrades script
Allowed origins are: o=Ubuntu,a=resolute, o=Ubuntu,a=resolute-security,
o=UbuntuESMApps,a=resolute-apps-security, o=UbuntuESM,a=resolute-infra-
security
Initial blacklist:
Initial whitelist (not strict):
Using (^linux-.*-[1-9][0-9]*\.[0-9]+\.[0-9]+-[0-9]+(-.+)?$|^kfreebsd-.*-[1-
```

```

9][0-9]*\.[0-9]+\.[0-9]+-[0-9]+(-.+)??|^gnumach-.*-[1-9][0-9]*\.[0-9]+\.[0-9]+-[0-9]+(-.+)??|^.*-modules-[1-9][0-9]*\.[0-9]+\.[0-9]+-[0-9]+(-.+)??|^.*-kernel-[1-9][0-9]*\.[0-9]+\.[0-9]+-[0-9]+(-.+)??|^linux-.*-[1-9][0-9]*\.[0-9]+\.[0-9]+-[0-9]+(-.+)??|^kfreebsd-.*-[1-9][0-9]*\.[0-9]+\.[0-9]+-[0-9]+(-.+)??|^gnumach-.*-[1-9][0-9]*\.[0-9]+\.[0-9]+-[0-9]+(-.+)??|^.*-modules-[1-9][0-9]*\.[0-9]+\.[0-9]+-[0-9]+(-.+)??|^.*-kernel-[1-9][0-9]*\.[0-9]+\.[0-9]+-[0-9]+(-.+)??) regexp to find kernel packages
Using (^linux-.*-7\.\0\.\0-22\-generic$|^linux-.*-7\.\0\.\0-22$|^kfreebsd-.*-7\.\0\.\0-22\-generic$|^kfreebsd-.*-7\.\0\.\0-22$|^gnumach-.*-7\.\0\.\0-22\-generic$|^gnumach-.*-7\.\0\.\0-22$|^.*-modules-7\.\0\.\0-22\-generic$|^.*-modules-7\.\0\.\0-22$|^.*-kernel-7\.\0\.\0-22\-generic$|^.*-kernel-7\.\0\.\0-22$|^linux-.*-7\.\0\.\0-22\-generic$|^linux-.*-7\.\0\.\0-22$|^kfreebsd-.*-7\.\0\.\0-22\-generic$|^kfreebsd-.*-7\.\0\.\0-22$|^gnumach-.*-7\.\0\.\0-22\-generic$|^gnumach-.*-7\.\0\.\0-22$|^.*-modules-7\.\0\.\0-22\-generic$|^.*-modules-7\.\0\.\0-22$|^.*-kernel-7\.\0\.\0-22\-generic$|^.*-kernel-7\.\0\.\0-22$) regexp to find running kernel packages
pkgs that look like they should be upgraded:
Fetched 0 B in 0s (0 B/s)
fetch.run() result: 0
Packages blacklist due to conffile prompts: []
Removing unused kernel packages: linux-modules-7.0.0-14-generic linux-tools-7.0.0-14 linux-tools-7.0.0-14-generic linux-headers-7.0.0-14-generic linux-headers-7.0.0-14 linux-main-modules-zfs-7.0.0-14-generic linux-image-unsigned-7.0.0-14-generic
marking linux-modules-7.0.0-14-generic for removal
marking linux-tools-7.0.0-14 for removal
marking linux-tools-7.0.0-14-generic for removal
marking linux-headers-7.0.0-14-generic for removal
marking linux-headers-7.0.0-14 for removal
marking linux-main-modules-zfs-7.0.0-14-generic for removal
marking linux-image-unsigned-7.0.0-14-generic for removal
Packages that were successfully auto-removed:
Packages that are kept back:
No packages found that can be upgraded unattended and no pending auto-removals
The list of kept packages can't be calculated in dry-run mode.
upgrade result: True No packages found that can be upgraded unattended and no pending auto-removals

```

- **Resultado e Indicación:**

- La simulación finalizó con éxito (upgrade result: True) sin reportar errores sintácticos en el archivo 99-seguridad-automatica . El log detalla los orígenes autorizados (Allowed origins) correspondientes a resolute-security en concordancia con la versión de desarrollo actual.

Punto 7: Bitácora de Auditoría de Seguridad y Medición con Lynis

Este documento registra de manera detallada las tareas de auditoría aplicadas en el servidor Ubuntu (192.168.1.109) utilizando la herramienta Lynis para evaluar el estado de seguridad antes y después de aplicar las técnicas de hardening del taller.

Resumen del Estado de las Tareas

Paso	Tarea	Estado
1	Instalación de Lynis	Completado
2	Ejecución de la Auditoría Inicial (Línea Base) y Registro del Índice	Completado
3	Ejecución de la Auditoría Final (Post-Hardening) y Registro del Índice	Completado
4	Comparativa de Índices y Análisis de 5 Sugerencias Pendientes	Completado

Desarrollo de Pasos y Registro de Evidencias

Paso 1: Instalación de Lynis

- **Descripción:** Se instala la herramienta Lynis en el servidor utilizando los repositorios oficiales de Ubuntu para realizar auditorías automáticas de hardening y cumplimiento.
- **Comandos a ejecutar en el Servidor (Ubuntu):**

```
sudo apt install lynis -y
```

- **Log del Comando (Proporcionado por el Usuario):**

```
vboxuser@ubuntu:~$ sudo apt install lynis -y
[Instalación de Lynis completada con éxito...]
```

- **Resultado e Indicación:**
 - La herramienta Lynis se instaló de forma correcta desde los repositorios de paquetes de Ubuntu, quedando lista para su ejecución.

Paso 2: Ejecución de la Auditoría Inicial (Línea Base) y Registro del Índice

- **Descripción:** Se corre una auditoría inicial utilizando Lynis para determinar el estado de seguridad base del sistema antes de las medidas de hardening.
- **Comando ejecutado en el Servidor (Ubuntu):**

```
sudo lynis audit system
```

- **Log del Comando (Proporcionado por el Usuario):**

```
vboxuser@ubuntu:~$ sudo lynis audit system
```

```
[sudo: authenticate] Password:
```

```
[ Lynis 3.1.6 ]
```

```
#####  
#####
```

```
Lynis comes with ABSOLUTELY NO WARRANTY. This is free software, and you  
are
```

```
welcome to redistribute it under the terms of the GNU General Public  
License.
```

```
See the LICENSE file for details about using this software.
```

```
2007-2025, CISOfy - https://cisofy.com/lynis/
```

```
Enterprise support available (compliance, plugins, interface and tools)
```

```
#####  
#####
```

```
[+] Initializing program
```

```
-----  
- Detecting OS... [ DONE ]
```

```
- Checking profiles... [ DONE ]
```

```
-----  
Program version:      3.1.6  
Operating system:     Linux  
Operating system name: Ubuntu  
Operating system version: 26.04  
End-of-life:          UNKNOWN  
Kernel version:       7.0.0  
Hardware platform:    x86_64  
Hostname:             ubuntu
```

```
-----  
Profiles:             /etc/lynis/default.prf
```

Log file: /var/log/lynis.log
Report file: /var/log/lynis-report.dat
Report version: 1.0
Plugin directory: /etc/lynis/plugins

Auditor: [Not Specified]
Language: en
Test category: all
Test group: all

- Program update status... [NO UPDATE]

=====
=====

Lynis might be outdated

=====
=====

Current version is more than 6 months old
Please check if there is a more recent version available.

=====
=====

[+] System tools

-
- Scanning available tools...
 - Checking system binaries...

[+] Plugins (phase 1)

Note: plugins have more extensive tests and may take several minutes to complete

- Plugin: debian
- [

[+] Debian Tests

-
- Checking for system binaries that are required by Debian Tests...
 - Checking /bin... [FOUND]
 - Checking /sbin... [FOUND]
 - Checking /usr/bin... [FOUND]

- Checking /usr/sbin... [FOUND]
- Checking /usr/local/bin... [FOUND]
- Checking /usr/local/sbin... [FOUND]
- Authentication:
 - PAM (Pluggable Authentication Modules):

[WARNING]: Test DEB-0001 had a long execution: 56.769630 seconds

- libpam-tmpdir [Not Installed]
- File System Checks:
 - DM-Crypt, Cryptsetup & Cryptmount:
 - Checking / on /dev/sda2 [NOT ENCRYPTED]
 - Software:
 - apt-listbugs [Not Installed]
 - apt-listchanges [Not Installed]
 - needrestart [Installed]
 - fail2ban [Not Installed]

[+] Boot and services

- Service Manager [systemd]
- Checking UEFI boot [DISABLED]
- Checking presence GRUB2 [FOUND]
 - Checking for password protection [NONE]
- Check running services (systemctl) [DONE]
 - Result: found 20 running services
- Check enabled services at boot (systemctl) [DONE]
 - Result: found 51 enabled services
- Check startup files (permissions) [OK]
- Running 'systemd-analyze security'
 - Result: analyzed units, found potential unsafe services
 - ModemManager.service (value=6.3) [MEDIUM]
 - chrony.service (value=3.7) [PROTECTED]
 - ssh.service (value=9.6) [UNSAFE]
 - ...

[+] Kernel

- Checking default runlevel [runlevel 5]

- Checking CPU support (NX/PAE) [FOUND]
- CPU support: PAE and/or NoeXecute supported [DONE]
- Checking kernel version and release [FOUND]
- Checking Linux kernel configuration file [NO]
- Check if reboot is needed

[+] Users, Groups and Authentication

- Administrator accounts [OK]
 - Unique UIDs [OK]
 - Sudoers file(s) [FOUND]
 - Permissions for directory: /etc/sudoers.d [WARNING]
 - Permissions for: /etc/sudoers [OK]
 - PAM password strength tools [SUGGESTION]
-]
- Determines default umask [SUGGESTION]
 - umask (/etc/login.defs)
-]

[+] File systems

- Mount options of /run [HARDENED]
 - Mount options of /tmp [PARTIALLY HARDENED]
 - Hidepid /proc mount [SUGGESTION]
-]

[+] Software: firewalls

- Checking host based firewall [NOT ACTIVE]
-]

[+] SSH Support

- Checking running SSH daemon [FOUND]
 - OpenSSH option: PermitRootLogin [OK]
 - OpenSSH option: PasswordAuthentication [OK]
 - OpenSSH option: AllowGroups [NOT FOUND]

[+] Software: Malware

- Malware software components [NOT FOUND]

[+] File Permissions

- Starting file permissions check [DONE]

[+] Kernel Hardening

- Comparing sysctl key pairs with scan profile [DONE]

[+] Hardening

- Installed compiler(s) [FOUND]
- Installed malware scanner [NOT FOUND]

=====

=====

-[Lynis 3.1.6 Results]-

Great, no warnings

Suggestions (46):

- * Install libpam-tmpdir to set \$TMP and \$TMPDIR for PAM sessions [DEB-0280]
- * Install apt-listbugs to display a list of critical bugs prior to each APT installation. [DEB-0810]
- * Install apt-listchanges to display any significant changes prior to any upgrade via APT. [DEB-0811]
- * Install fail2ban to automatically ban hosts that commit multiple authentication errors. [DEB-0880]
- * Set a password on GRUB boot loader to prevent altering boot configuration [BOOT-5122]
- * Default umask in /etc/login.defs could not be found and defaults usually to 022, which could be more strict like 027 [AUTH-9328]
- * Install a PAM module for password strength testing like pam_cracklib or pam_passwdqc or libpam-passwdqc [AUTH-9262]
- * Configure a firewall/packet filter to filter incoming and outgoing traffic [FIRE-4590]
- * Install a file integrity tool to monitor changes to critical and sensitive files [FINT-4350]
- * Harden compilers like restricting access to root user only [HRDN-7222]
- * Harden the system by installing at least one malware scanner, to perform periodic file system scans [HRDN-7230]
- ... [Lista completa de 46 sugerencias en /var/log/lynis.log]

=====

=====

Lynis security scan details:

```
Hardening index : 61 [#####  
Tests performed : 255  
Plugins enabled : 1
```

Software components:

```
- Firewall [X]  
- Intrusion software [X]  
- Malware scanner [X]
```

```
=====
```

- **Evidencia:**

![Auditoría Inicial - Lynis](lynis pre.jpeg)

- **Resultado e Indicación:**

- **Hardening Index Inicial: 61**
- **Software Components Detectados:**
 - Firewall: [X] (Deshabilitado/Inactivo)
 - Intrusion software: [X] (Ninguno detectado/Fail2ban inactivo)
 - Malware scanner: [X] (No configurado)
- El sistema inicialmente contaba con un índice de 61 puntos, evidenciando una superficie de ataque expuesta debido a la inactividad del firewall y la ausencia de software de detección de intrusiones.

Paso 3: Ejecución de la Auditoría Final (Post-Hardening) y Registro del Índice

- **Descripción:** Se ejecuta la auditoría final tras aplicar las medidas de endurecimiento descritas en los puntos anteriores (UFW habilitado con reglas estrictas y Fail2ban configurado y activo).
- **Comando ejecutado en el Servidor (Ubuntu):**

```
sudo lynis audit system
```

- **Log del Comando (Proporcionado por el Usuario):**

```
vboxuser@ubuntu:~$ sudo lynis audit system
```

```
[ Lynis 3.1.6 ]
```

```
#####  
#####
```

```
Lynis comes with ABSOLUTELY NO WARRANTY. This is free software, and you
```

are

welcome to redistribute it under the terms of the GNU General Public License.

See the LICENSE file for details about using this software.

2007-2025, CISOfy - <https://cisofy.com/lynis/>

Enterprise support available (compliance, plugins, interface and tools)

#####

[+] Initializing program

- Detecting OS... [DONE]
- Checking profiles... [DONE]

Program version: 3.1.6
Operating system: Linux
Operating system name: Ubuntu
Operating system version: 26.04
End-of-life: UNKNOWN
Kernel version: 7.0.0
Hardware platform: x86_64
Hostname: ubuntu

Profiles: /etc/lynis/default.prf
Log file: /var/log/lynis.log
Report file: /var/log/lynis-report.dat
Report version: 1.0
Plugin directory: /etc/lynis/plugins

Auditor: [Not Specified]
Language: en
Test category: all
Test group: all

- Program update status... [NO UPDATE]

=====
=====

Lynis might be outdated

=====
=====

Current version is more than 6 months old
Please check if there is a more recent version available.

=====

[+] System tools

- Scanning available tools...
- Checking system binaries...

[+] Plugins (phase 1)

Note: plugins have more extensive tests and may take several minutes to complete

- Plugin: debian

[+] Debian Tests

- Checking for system binaries that are required by Debian Tests...
 - Checking /bin... [FOUND]
 - Checking /sbin... [FOUND]
 - Checking /usr/bin... [FOUND]
 - Checking /usr/sbin... [FOUND]
 - Checking /usr/local/bin... [FOUND]
 - Checking /usr/local/sbin... [FOUND]
- Authentication:
 - PAM (Pluggable Authentication Modules):

[WARNING]: Test DEB-0001 had a long execution: 63.246589 seconds

- libpam-tmpdir [Not Installed]
- File System Checks:
 - DM-Crypt, Cryptsetup & Cryptmount:
 - Checking / on /dev/sda2 [NOT ENCRYPTED]
 - Software:
 - apt-listbugs [Not Installed]
 - apt-listchanges [Not Installed]

```
    - needrestart [ Installed ]
    - fail2ban [ Installed ]
with jail.local ]
]
```

[+] Boot and services

```
-----
- Service Manager [ systemd ]
- Checking UEFI boot [ DISABLED ]
- Checking presence GRUB2 [ FOUND ]
  - Checking for password protection [ NONE ]
- Check running services (systemctl) [ DONE ]
  Result: found 21 running services
- Check enabled services at boot (systemctl) [ DONE ]
  Result: found 52 enabled services
- Check startup files (permissions) [ OK ]
- Running 'systemd-analyze security'
  Result: analyzed units, found potential unsafe services
  - ModemManager.service (value=6.3) [ MEDIUM ]
  - chrony.service (value=3.7) [ PROTECTED ]
  - ssh.service (value=9.6) [ UNSAFE ]
  ...
```

[+] Kernel

```
-----
- Checking default runlevel [ runlevel 5 ]
- Checking CPU support (NX/PAE)
  CPU support: PAE and/or NoeXecute supported [ FOUND ]
- Checking kernel version and release [ DONE ]
- Checking Linux kernel configuration file [ FOUND ]
- Check if reboot is needed [ NO ]
```

[+] Users, Groups and Authentication

```
-----
- Administrator accounts [ OK ]
- Unique UIDs [ OK ]
- Sudoers file(s) [ FOUND ]
  - Permissions for directory: /etc/sudoers.d [ WARNING ]
  - Permissions for: /etc/sudoers [ OK ]
- PAM password strength tools [ OK ]
- Determines default umask
  - umask (/etc/login.defs) [ SUGGESTION ]
]
```

[+] File systems

```

-----
- Mount options of /run [ HARDENED ]
- Mount options of /tmp [ PARTIALLY
HARDENED ]
- Hidepid /proc mount [ SUGGESTION
]

[+] Software: firewalls
-----
- Checking host based firewall [ ACTIVE ]

[+] SSH Support
-----
- Checking running SSH daemon [ FOUND ]
- OpenSSH option: PermitRootLogin [ OK ]
- OpenSSH option: PasswordAuthentication [ OK ]
- OpenSSH option: AllowGroups [ NOT FOUND ]

[+] Software: Malware
-----
- Malware software components [ NOT FOUND ]

[+] File Permissions
-----
- Starting file permissions check [ DONE ]

[+] Kernel Hardening
-----
- Comparing sysctl key pairs with scan profile [ DONE ]

[+] Hardening
-----
- Installed compiler(s) [ FOUND ]
- Installed malware scanner [ NOT FOUND ]

=====
=====

-[ Lynis 3.1.6 Results ]-

Great, no warnings

Suggestions (43):
-----
* Install libpam-tmpdir to set $TMP and $TMPDIR for PAM sessions [DEB-
0280]

```

```

* Install apt-listbugs to display a list of critical bugs prior to each
APT installation. [DEB-0810]
* Install apt-listchanges to display any significant changes prior to any
upgrade via APT. [DEB-0811]
* Set a password on GRUB boot loader to prevent altering boot
configuration [BOOT-5122]
* Default umask in /etc/login.defs could not be found and defaults
usually to 022, which could be more strict like 027 [AUTH-9328]
* Install a file integrity tool to monitor changes to critical and
sensitive files [FINT-4350]
* Harden compilers like restricting access to root user only [HRDN-7222]
* Harden the system by installing at least one malware scanner, to
perform periodic file system scans [HRDN-7230]
... [Lista completa de 43 sugerencias en /var/log/lynis.log]

```

```

=====
=====

```

Lynis security scan details:

```

Hardening index : 67 [#####          ]
Tests performed : 257
Plugins enabled : 1

```

Software components:

```

- Firewall           [V]
- Intrusion software [V]
- Malware scanner    [X]

```

```

=====
=====

```

- **Evidencia:**

![[Auditoría Final - Lynis](lynis pos.jpeg)]

- **Resultado e Indicación:**

- **Hardening Index Final: 67**
- **Software Components Detectados:**
 - Firewall: [V] (Habilitado y activo - UFW)
 - Intrusion software: [V] (Habilitado y activo - Fail2ban)
 - Malware scanner: [X] (Aún pendiente)
- **Análisis de la Mejora:** El Hardening Index incrementó de **61 a 67 puntos** (+6 puntos de mejora). Lynis detectó y validó con éxito que tanto el Firewall como el software de

detección de intrusiones (Intrusion software) ahora están en funcionamiento activo ([V]), disminuyendo la vulnerabilidad general del sistema.

Paso 4: Comparativa de Índices y Análisis de 5 Sugerencias Pendientes

- **Descripción:** Aunque la puntuación aumentó significativamente, una auditoría completa de seguridad siempre deja áreas abiertas para continuar el proceso de hardening. A continuación se detallan 5 sugerencias de Lynis a considerar:
 1. **[BOOT-5122] Set a password on GRUB boot loader:**
 - *Explicación Técnica:* Por defecto, el cargador de arranque GRUB permite a cualquiera con acceso a la pantalla de VirtualBox (o consola física) editar los parámetros del kernel durante el arranque (presionando `e`) y arrancar en modo monousuario (single-user mode) o invocar `/bin/bash` directamente con privilegios de root sin contraseña. Añadir contraseña en GRUB restringe este vector.
 2. **[HRDN-7222] Harden compilers like restricting access to root user only:**
 - *Explicación Técnica:* Si un atacante comprometiera una cuenta de usuario con bajos privilegios, buscará compilar exploits de escalado de privilegios en caliente. Restringir la ejecución de los compiladores del sistema (como gcc, clang) para que solo root los ejecute reduce drásticamente esta capacidad.
 3. **[FINT-4350] Install a file integrity tool to monitor changes to critical files:**
 - *Explicación Técnica:* Instalar sistemas como AIDE o Tripwire para calcular sumas criptográficas (hashes) de binarios y configuraciones del sistema. Cualquier modificación no autorizada (por ejemplo, por la instalación de un troyano o rootkit) alertará de inmediato al administrador.
 4. **[HRDN-7230] Harden the system by installing at least one malware scanner:**
 - *Explicación Técnica:* Instalar escáneres automáticos de rootkits y backdoors como rkhunter o chkrootkit para programar auditorías periódicas y detectar firmas de amenazas conocidas.
 5. **[AUTH-9328] Default umask in /etc/login.defs could be more strict like 027:**
 - *Explicación Técnica:* La máscara de permisos por defecto suele ser 022 (lo que crea archivos legibles para cualquier usuario). Modificarla a 027 asegura que las nuevas creaciones de archivos y directorios no sean legibles por otros usuarios del sistema que no pertenezcan al grupo propietario.

Pregunta de Análisis: Limitaciones de Lynis y la Visión Integral de Seguridad

El Hardening Index de Lynis no es el único indicador de seguridad.

¿Qué aspectos de la seguridad de un servidor NO evalúa Lynis?

Aunque Lynis es una herramienta excelente de auditoría estática del sistema operativo local (comprobando permisos, configuraciones en archivos de texto, presencia de herramientas y llaves sysctl), tiene un alcance acotado al entorno del sistema operativo local hospedado.

Lynis NO evalúa los siguientes aspectos críticos de seguridad:

1. Vulnerabilidades y Lógica de Negocio de Aplicaciones (Capa 7):

- Lynis verifica si un servicio web como Apache o Nginx está instalado y si corre bajo un usuario seguro, pero no realiza pruebas dinámicas del código (DAST/SAST). No puede detectar fallos de inyección SQL, Cross-Site Scripting (XSS), fallas de control de acceso funcional (BOLA) o lógica interna vulnerable de la aplicación.

2. Políticas de Privacidad y Gestión de Accesos (Identity & Access Management - IAM):

- Audita archivos locales (/etc/passwd , /etc/shadow), pero no evalúa la fortaleza de políticas corporativas basadas en proveedores centralizados (como Active Directory, LDAP externo, Azure AD, OAuth2 o SSO). No detecta si se están asignando permisos excesivos en la consola de la nube (AWS, GCP, Azure) para interactuar con el servidor.

3. Seguridad Física e Hipervisor (Capa de Infraestructura):

- Al ejecutarse dentro del sistema operativo virtualizado, Lynis no tiene visibilidad de las vulnerabilidades en el hipervisor (como VirtualBox, VMware ESXi o KVM) que podrían permitir una fuga de máquina virtual (VM Escape). Tampoco puede evaluar la seguridad física de los servidores o racks.

4. Cifrado de Datos en Tránsito de Extremo a Extremo (Red Externa):

- Evalúa la presencia de certificados y opciones estáticas de SSH/SSL, pero no comprueba dinámicamente si el tráfico de red está circulando sin cifrar fuera de la máquina (por ejemplo, a través de routers intermedios inseguros en la LAN) ni si se emplean túneles VPN robustos.

5. Auditoría de Red Dinámica y Simulación de Ataques (Pentesting/Penetration Testing):

- Realiza un análisis estático de puertos abiertos y el cortafuegos, pero no simula ataques externos ni realiza escaneos dinámicos de red (como lo haría Nmap, Nessus o un analista mediante exploits reales) para comprobar cómo responden las herramientas de detección de intrusiones en la práctica ante un Zero-Day de red.

6. Ingeniería Social y Factor Humano:

- La seguridad de un servidor depende críticamente del comportamiento humano. Lynis no evalúa el nivel de concientización de los administradores ante ataques de Phishing, Spear-Phishing o estafas para revelar contraseñas del sistema.